

Rapport d'Audit de Conformité Sécurité (SCA)

Évaluation de la configuration de référence (Baseline Security Position) via Wazuh SIEM/XDR

Date de l'audit :	28 juin 2026	Rédacteur :	Antoine A. (Analyste Sécurité)
Périmètre audité :	Contrôleurs de Domaine Actifs & Infrastructure Hôte Linux	Solution de scan :	Wazuh Security Configuration Assessment (SCA)
Classification :	Restreint / Usage Interne	Référence DAT :	Section 5.2 - Audits de Durcissement

1. SYNTHÈSE EXÉCUTIVE

Ce document consigne les résultats du premier audit automatisé de conformité sécurité, réalisé via le module **SCA (Security Configuration Assessment)** de notre solution SIEM/XDR **Wazuh**. Cet audit a été exécuté immédiatement après le provisionnement initial des serveurs afin d'évaluer la posture de sécurité "par défaut" (*Out-of-the-Box*) de nos systèmes critiques avant l'application des politiques globales de durcissement (*Hardening*).

Le périmètre de cette évaluation comprend les infrastructures centrales du système d'information de l'entreprise : d'une part, les deux contrôleurs de domaine Windows Server assurant la gestion des identités et la réplication inter-sites (Genève et Paris) ; d'autre part, le serveur Linux Debian hébergeant notre pile logicielle conteneurisée.

Note d'ingénierie : L'analyse des résultats met en évidence d'importants écarts par rapport aux guides de bonnes pratiques de l'industrie (CIS Benchmarks). Ces vulnérabilités configurationnelles initiales, inhérentes aux configurations d'usine des éditeurs, confirment l'importance de déployer une solution de surveillance continue et d'instaurer un plan de remédiation strict (modèle Zero Trust) pour atteindre le seuil de conformité cible fixé à 70 %.

Tableau de Synthèse Métrique des Scores SCA

Désignation de l'Hôte	Adresse IP	Système d'Exploitation	Référentiel de Sécurité appliqué	Total Tests	Passed	Failed	Score Global
DC-GENEVE	10.0.10.10	Windows Server 2022 Core	CIS Microsoft Windows Server 2022 v3.0.0	357	88	269	25 %
DC-PARIS	10.0.11.10	Windows Server 2022 Core	CIS Microsoft Windows Server 2022 v3.0.0	357	88	269	25 %
docker-host	10.0.20.10	Debian GNU/Linux 12	CIS Debian Linux 12 Benchmark v1.0.0	186	66	120	35 %

2. ÉVALUATION DES CONTRÔLEURS DE DOMAINE WINDOWS (SCORE : 25%)

Les deux contrôleurs de domaine (DC-GENEVE et DC-PARIS) partagent une architecture identique et remontent un score strictement corrélé de **25%**, validant 88 contrôles et échouant sur 269. Cette forte proportion d'échecs s'explique par l'absence d'objets de stratégie de groupe (GPO) de sécurité appliqués au moment du scan.

Analyse des Facteurs de Réussite (88 Passed)

Les succès enregistrés découlent principalement de notre décision d'architecture d'opter pour le mode **Windows Server Core**. En éliminant l'interface graphique (GUI) et l'ensemble des sous-systèmes multimédias ou applicatifs utilisateurs (navigateurs, utilitaires d'impression locaux), la surface d'attaque est naturellement restreinte, ce qui valide d'office les règles CIS interdisant les composants superflus. Les politiques de base de longueur et de complexité de mots de passe, requises nativement lors de la promotion de la forêt `cyna.local`, contribuent également à ces validations.

Analyse des Écarts Majeurs (269 Failed)

La majorité des non-conformités découle des réglages par défaut de Microsoft, conçus historiques pour maximiser la compatibilité au détriment de la sécurité :

- **Persistance de protocoles de résolution obsolètes** : Les services LLMNR (*Link-Local Multicast Name Resolution*) et NetBIOS restent activés. En l'absence de serveur DNS pour une requête donnée, ces protocoles émettent des requêtes en broadcast, exposant l'infrastructure à des attaques par empoisonnement de flux (de type Responder).
- **Absence de signature numérique obligatoire** : Le protocole SMB (*Server Message Block*) n'impose pas la signature systématique des paquets par défaut. Un attaquant en situation d'interposition (Man-in-the-Middle) pourrait intercepter et modifier les flux d'administration ou de réplication Active Directory.
- **Déficit de journalisation d'audit** : La politique locale d'audit de sécurité ne trace pas de manière exhaustive les privilèges d'accès, les accès aux objets système et les modifications de droits, masquant d'éventuels mouvements latéraux.

VULNÉRABILITÉ CRITIQUE IDENTIFIÉE :

L'activation par défaut de la résolution anonyme des comptes (*RestrictAnonymous* positionné à 0) permet à un utilisateur non authentifié d'énumérer les noms des comptes du domaine et les partages IPC\$ via le réseau. Cette configuration facilite grandement les phases de reconnaissance lors d'une attaque.

3. ÉVALUATION DE L'HÔTE LINUX DEBIAN 12 (SCORE : 35%)

Le serveur `docker-host`, configuré pour l'hébergement de notre infrastructure SOC, présente un score initial de **35%** (66 succès pour 120 échecs). Ce résultat reflète un compromis technique temporaire mis en œuvre pour stabiliser l'environnement sous contrainte de ressources matérielles.

Analyse des Facteurs de Réussite (66 Passed)

Le durcissement du service d'accès distant **SSH** est entièrement conforme (interdiction de l'accès direct en `root`, protocoles SSH v1 bannis, algorithmes de chiffrement obsolètes désactivés). De plus, les configurations du noyau Linux liées à l'allocation de la mémoire virtuelle (`vm.max_map_count=262144`), nécessaires pour assurer la stabilité du moteur d'indexation OpenSearch de Wazuh, ont été reconnues stables et conformes par l'outil d'audit.

Analyse des Écarts Majeurs (120 Failed)

Les manquements de sécurité relevés se concentrent sur la gestion fine du système d'exploitation et de l'orchestrateur de conteneurs :

- **Inexistence d'un démon d'audit noyau** : Le paquet `auditd` n'est pas installé. Les appels système sensibles (modifications de fichiers de configuration, exécutions de binaires privilégiés) ne font l'objet d'aucune journalisation locale persistante.
- **Exposition des interfaces de communication de conteneurs** : Les fichiers clés de configuration, notamment `/etc/docker/daemon.json` et le socket local `docker.sock`, possèdent des permissions de lecture/écriture trop permissives, ouvrant une possibilité d'élévation de privilèges de l'espace conteneurisé vers l'hôte Linux.
- **Politique de filtrage réseau local manquante** : Le pare-feu local Netfilter (Iptables/Ufw) n'embarque aucune restriction de flux stricte sur l'hôte, le cloisonnement des flux étant entièrement délégué aux pare-feux périmétriques pfSense.

4. PLAN DE REMÉDIATION ET DURCISSEMENT DES SYSTÈMES

Pour corriger ces vulnérabilités et aligner l'infrastructure sur les exigences cibles (score SCA $\geq 70\%$), une feuille de route technique axée sur l'automatisation est planifiée.

1. Déploiement d'une GPO de Durcissement Active Directory

Afin de corriger simultanément les 269 échecs constatés sur les contrôleurs de domaine de Genève et Paris, la création d'une Group Policy Object (GPO) restrictive à la racine de la forêt Active Directory est prioritaire. Cette GPO appliquera :

- La désactivation complète de LLMNR via le paramètre : `Désactiver la résolution de noms multicast descendante`.
- L'obligation de signature des communications SMB client et serveur (`Microsoft network server: Digitally sign communications (always) = Enabled`).
- La modification de la clé de registre de l'autorité de sécurité locale (LSA) pour imposer `RestrictAnonymous = 1`.

2. Industrialisation du durcissement Linux via playbooks Ansible

Pour le serveur hôte Docker, l'intégration des correctifs de sécurité se fera par le biais d'un playbook de configuration (Infrastructure as Code) afin de systématiser les actions suivantes :

1. Installation et configuration d'`auditd` avec un jeu de règles CIS restreint pour limiter l'impact sur la mémoire RAM.
2. Application d'un profil de droits d'accès strict sur l'arborescence Docker (`chmod 600 /etc/docker/daemon.json`).
3. Définition d'une directive `ClientAliveInterval 300` dans la configuration du démon SSH pour purger automatiquement les sessions inactives.

3. Validation des correctifs

Suite à l'application de ces mesures correctives, une réévaluation complète via le module SCA de Wazuh sera déclenchée pour valider l'élévation des indices de conformité et consigner la nouvelle base de sécurité de l'organisation.

* FIN DU DOCUMENT — CYNA SÉCURITÉ INFRASTRUCTURE *